MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 022 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · AI AND CUI

Can You Put CUI in an AI Tool? Read the Cloud Clause First

The DFARS clause that governs cloud service providers already answers whether CUI can go into an AI tool - most of the commercial tier fails it.

BY **MAXINE** READING TIME · 6 MIN CUI · DFARS · AI · CLOUD

Here is the answer every program manager wants: it is just text in a box. You type a question, a model answers, nothing is stored on a server you control, and the whole exchange feels closer to a very fast search than to shipping a file offsite. Copilot is already in the productivity suite half your staff uses daily. ChatGPT and Claude are one tab away from anyone with a browser. If the words never touch a drive, the instinct runs, they never left the building - so a program office under deadline pressure treats the question as settled and moves on to the next fire.

The instinct is wrong, and it is wrong for a reason that has nothing to do with how good the model is. It has to do with where the words go after you hit enter.

The clause that already answered this

DFARS 252.204-7012(b)(2)(ii)(D) does not mention artificial intelligence, and it does not need to. It governs any external cloud service provider a contractor uses to store, process, or transmit covered defense information, and it sets the bar plainly: the provider has to meet the FedRAMP Moderate baseline, or demonstrate equivalence to it, and the contractor has to flow the clause's incident-reporting and media-preservation obligations down into the vendor relationship. Nothing in that sentence cares whether the processing looks like a database write or a chat completion. A hosted large language model that ingests your prompt, runs it through infrastructure the vendor operates, and returns a response is processing your data on someone else's cloud - which makes the vendor a cloud service provider under the clause, in exactly the sense DFARS 7012 was written to reach.

That one sentence disposes of most of the commercial AI tier before a compliance officer has to evaluate a single model's answer quality. It is not a question of whether the model is trustworthy, careful, or well-trained. It is a question of whether the infrastructure underneath it sits on a FedRAMP Moderate authorization or its documented equivalent, and whether the vendor's contract actually commits to the 72-hour reporting clock and the media-preservation duties DFARS 7012 requires when an incident happens. Most consumer-tier AI products were never built against that bar, because the bar was never the product's audience. That does not make a specific product permitted or forbidden - authorization status moves monthly, and the only current record of it is the FedRAMP Marketplace, not a vendor's marketing page or a program manager's assumption. It does mean the question "can I use this tool" collapses into a question everyone in a CMMC program already knows how to ask about a cloud vendor: where's the authorization, and does the contract carry the flow-down. If nobody has asked that question about a given AI product, the honest interim answer is no, not yet.

The failure that never shows up as a breach

Here is what the clause does not do: it does not stop anyone from using these tools. A DFARS paragraph has no technical control over a browser tab. What it actually changes is whether people admit to using them - and that gap between practice and disclosure is the more dangerous failure mode by a wide margin, because it never announces itself the way a data spill does.

FIELD COPY
ISSUE Nº 022
CUI

(b)(2)(ii)(D)

THE DFARS 252.204-7012 SUBPARAGRAPH THAT TURNS "WHICH AI TOOL" INTO "WHICH CLOUD SERVICE PROVIDER"

72 hrs

THE INCIDENT-REPORTING CLOCK A COMPLIANT AI VENDOR'S CONTRACT HAS TO CARRY, SAME AS ANY OTHER CLOUD PROVIDER

3.4.1 / 3.12.4

THE NIST 800-171 REQUIREMENTS AN UNLISTED AI TOOL BREAKS BEFORE A SINGLE PROMPT EVER LEAVES THE BUILDING

◆ CHECK THE MARKETPLACE, NOT THE SALES REP

FedRAMP authorization status changes month to month, and a vendor's own claim about it is not the record. The FedRAMP Marketplace is the record - look up the specific product and the specific baseline before you believe anything else.

Picture the realistic version. An engineer pastes a paragraph of a design narrative into an AI assistant to tighten the prose, not because they intend to leak anything, but because the tool is fast and the deadline is real. Nobody tells the compliance lead. The System Security Plan, meanwhile, describes a system that matches the network diagram from eighteen months ago - accurate as history, silent on the tool three people now use every week. That gap is not a hypothetical the next assessment surfaces by accident. It is a defect against 3.4.1, which requires an accurate inventory of authorized components, and against 3.12.4, which requires a system security plan that describes the system as it actually operates, not as it was designed to operate. An assessor who finds an AI tool in active use that the SSP never mentions has not caught a rogue employee. They have caught a governance failure - proof that the plan of record and the system of record diverged, and nobody was tracking either.

That is the shape shadow AI actually takes in a CUI environment: quiet, well-intentioned, and invisible right up until someone with assessment authority goes looking for it. The MacTech Suite illustrates the alternative principle, though on a much smaller footprint than a defense contractor's document flow - every automated action inside it is gated by role, and every gated action lands in an append-only audit log a database trigger will not let anyone edit after the fact (more on how that runs). Constrained and recorded is the property that matters. It is not a claim that any AI tool is cleared to touch CUI; it is what "cleared to touch CUI" would have to look like if something eventually were.

The clause does not stop anyone from using these tools. It stops them from admitting they use them.

What a defensible yes actually requires

None of this means the answer to "can we use AI at all" is a flat no. It means the defensible version of yes is unglamorous, and it looks a lot like the other CUI boundary decisions your program has already made.

Start with an honest inventory - not a policy stating employees may not use unauthorized tools, but an actual accounting of which AI tools people are using today, gathered by asking rather than assuming the policy is self-enforcing. Pair it with a written boundary decision about where a model is allowed to run relative to the CUI enclave: entirely outside it, walled off from anything that touches covered defense information, the same way enclave scoping already draws that line for every other category of tool. Where a vendor relationship is worth pursuing, get the flow-down in the contract itself, not implied by a privacy policy - the incident-reporting clock and the media-preservation duty have to be terms the vendor has actually accepted, in writing, not obligations you hope apply. And treat every prompt as a data flow on the SSP diagram, the same as a database connection or a file transfer, because that is what it is: information leaving one boundary and entering another, whether or not it passes through anything that looks like a file.

None of that is exotic. It is the same discipline a compliance program already applies to any other external service, applied to a category of vendor that arrived faster than most programs' governance did. The transferable principle is the one worth carrying past this specific clause: AI belongs in a regulated environment when its actions are constrained and recorded, not when the model is impressive. A tool that never touches CUI needs none of this. A tool that might is either inventoried, bounded, contracted, and diagrammed, or it is a finding waiting for an assessor to notice it before you do. Talk to MacTech if you are still building that inventory. ◆
